AI Identity: Human Sign-In and Agent Access

Mode 2 Phase 1 (Building Blocks), Chapter 6/6 — Revision & Viva-Prep Cheatsheet (English + Roman Urdu)
Source: agentfactory.panaversity.org/docs/ai-identity-crash-course

EN: Whose identity is this, and how does authority reach from a human to an agent? First own your own sign-in, then give an agent its OWN (never borrowed) identity -- scoped, time-boxed, revocable, human-approved.
Roman Urdu: Yeh identity kiski hai, aur authority insaan se agent tak kaise pohanchti hai? Pehle apna sign-in own karo, phir agent ko uski APNI (borrowed nahi) identity do -- scoped, time-boxed, revocable, human-approved.

1. Venue Metaphor + Owning Your Sign-In

- Door=Sign-in, Booth=Issuer, Wristband=Token, Bartender=Validator. The booth holds a private key (seal) and publishes a public photo -- others can verify it, never forge it.
- **7-step build spine:** Base -> Sign-in -> Issuer -> Scopes/Consent -> Real app -> Resource server (stable) -> CIMD (edge) -> Agent credential/on-behalf-of (frontier, beta).

2. Becoming the Issuer + Scopes & Consent

- Becoming the issuer means you now sign tokens other apps verify themselves (no DB call, just the public seal). PKCE proves the same app started and finished the flow.
- A token exactly states what's allowed; the consent screen shows that exact list -- this is what makes least privilege real, not aspirational.

3. Resource Server + CIMD

- A resource server takes a bearer token, reads aud, checks the signing algorithm (RS256) -- 4 attack tests: wrong algorithm, alg:none, HMAC-as-secret forgery, wrong audience.
- **CIMD** (Client ID Metadata Document) skips pre-registration -- the app publishes its own public sign at its own URL.

4. Frontier: Identity for Agents

- Today's wrong pattern: one shared master token photocopied across all agents -- revoking it revokes everyone. Fix: EACH agent gets its own token with its own limits, individually revocable.
- **5-step flow:** Discover -> Register (host vouches) -> Approve (device-code/policy) -> Sign (agent signs its own short-lived token) -> Verify+run.
- **On-Behalf-Of:** the token names BOTH the agent and the human; human approval must happen before the authority exists, not after.

Key Terms Cheatsheet

One line each — English + Roman Urdu.

Term	English	Roman Urdu
Issuer	The party that signs tokens; others verify with its public key, no DB call needed.	Woh party jo tokens sign karti; doosre uski public key se verify karte, DB call zaroori nahi.
aud (audience)	The claim proving a token was stamped FOR this specific app.	Claim jo prove karta token specifically is app ke liye stamped tha.
PKCE	Proof the same app that started the OAuth flow also finished it.	Proof ke OAuth flow shuru karne wali app ne hi khatam ki.
CIMD	Client ID Metadata Document -- skips pre-registration by publishing a public sign at the app's own URL.	Client ID Metadata Document -- app apni URL par public sign publish kar ke pre-registration skip karta.
On-Behalf-Of	A token naming both the agent and the human it acts for, needing prior human approval.	Token jo agent aur jis human ke liye act karta dono naam leta, prior human approval zaroori.

Quick Self-Check

Question	Answer
Why is today's common pattern (one shared master token for all agents) dangerous?	Revoking it revokes every agent at once -- there's no way to individually limit or revoke a single agent's access.
What's the fix the frontier pattern proposes?	Each agent gets its own short-lived, individually-revocable, scoped token instead of a shared master credential.
Why must human approval for On-Behalf-Of authority happen BEFORE the action, not after?	Authority must exist before it's used -- approving after the fact isn't consent, it's just a record of what already happened.
What does CIMD let an app skip?	Pre-registration with the issuer -- the app instead publishes its own public sign at its own URL for the booth to read on first contact.

Where This Leads / Sources

Leads to: Build AI Agents, Building a Digital FTE (agent credentials in production). Full 7-step build + attack tests in 01-05.

Source: docs/ai-identity-crash-course/ (this repo), content originally via Zia Tutor AI connector.